

Aws-Security course

עבודת סיכום למסלול מגנים באתר flaws2.cloud

Objective1: התחברות לחשבון ה security דרך ה cli

המשימה הראשונה הייתה להתחבר ל CLI של חשבון ה Security של התרגיל ולבצע הורדה של דוחות ה cloudtrail, בוצעה התחברות מוצלחת עי access/secret keys בתמונה של החיבור אנחנו רואים את ההגדרה של המשתמש ב cli , הפעולה מתבצעת עם הפקודה "aws configure" ואז נזין את access/secret keys נציין את הריג'ן של הבאקט במקרה שלנו כי אנחנו צריכים את הלוגים והם מאוחסנים במקרה הזה בבאקט שיושב ב-us-east 1

```
File Actions Edit View Help
(shlomi@~)-[~]
$ aws configure
AWS Access Key ID [*****T3PG]: AKIAIUFNQ2WCOPTTEITJQ
AWS Secret Access Key [*****cfjP]: paVI8VgTWkPI3jDNkdzUMvK4CcdX02T7sePX0ddF
Default region name [us-east-1]:
Default output format [None]:

(shlomi@~)-[~]
$
```

בפקודה הראשונה אנחנו מוודאים את חיבור ה CLI לחשבון ה security עי הפקודה

Aws sts get-caller-identity

```
File Actions Edit View Help
(shlomi@~)-[~/sec_course]
$ aws configure
AWS Access Key ID [*****ITJQ]:
AWS Secret Access Key [*****ddF]:
Default region name [us-east-1]:
Default output format [None]:

(shlomi@~)-[~/sec_course]
$ aws sts get-caller-identity
{
  "UserId": "AIDA3XZBU42TFRNGBBFI",
  "Account": "322079859186",
  "Arn": "arn:aws:iam::322079859186:user/security"
}

(shlomi@~)-[~/sec_course]
$ aws s3 sync s3://Flaws2-logs /home/shlomi/sec_course
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T2310Z_rp9i9xR2Vcpqfnz.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T2310Z_rp9i9xR2Vcpqfnz.json.gz
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T2352_cr9ra7OH1rytWYXY.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T2352_cr9ra7OH1rytWYXY.json.gz
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T23052_83VTW28Z0kiEC7Lq.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T23052_83VTW28Z0kiEC7Lq.json.gz
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T2310Z_jQa3Cuioboj08I4y.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T2310Z_jQa3Cuioboj08I4y.json.gz
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T23052_zKLMhON7Ephala9u.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T23052_zKLMhON7Ephala9u.json.gz
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T2310Z_739NEIxrjJsrX5d.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T2310Z_739NEIxrjJsrX5d.json.gz
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T2310Z_jW5HfNtz7KOnvcP.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T2310Z_jW5HfNtz7KOnvcP.json.gz
download: s3://Flaws2-logs/AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_us-east-1_20181128T2310Z_A1lh3sWzRIBFVx.json.gz to AWSLogs/653711331788/CloudTrail/us-east-1/2018/11/28/653711331788_CloudTrail_u
s-east-1_20181128T2310Z_A1lh3sWzRIBFVx.json.gz

(shlomi@~)-[~/sec_course]
$
```

"Sts"-security Token service:

זהו סרוויס גלובלי הפועל מאחורי הקלעים המאפשר לנו לייצור גישה למערכת לזמן מוגבל, אנחנו בעצם מקבלים credentials שהם כמו secret\access keys אנחנו מחליטים את זמן ההרשאה, כאשר הקמנו לראשונה ב AWS את החשבון שלנו בעצם השתמשנו בסרוויס ללא ידעתנו

Get"

זוהי פקודת שמבצעת את ה"יבוא"-במקרה שלנו זה אנחנו רוצים להביא את זהות המשתמש ב CLI

"caller-identity" מחזיר לנו מידע אודות משתמשי iam -ה caller הוא ה iam user, זה identity זהו מידע אודות זהות המשתמש שביצע את הזיהוי ל cli בעצם בפקודה הראשונה אנחנו מוודאים את ההתחברות שלנו ל CLI עי הפקודה הנ"ל-אחרי שביצענו אותה-קיבלנו את הפלט עם זהות המשתמש ב cli

פקודה שנייה: הורדת הדוחות Cloudtrail

שהוא שירות בסיסי של AWS שמתעד את כל הפעילות שמתבצעת ע"י משתמשים בכל חשבונות ה-AWS ב-Organization. כל פעולה במערכת, כל שימוש ב-API של AWS מתועד ב-CloudTrail וניתן לדעת בדיוק מי ביצע מה ומתי, את הלוגים אפשר לשלוח ל cloudwatch ואפשר גם לאחסן אותן ב s3 bucket

מתבצעת עי הפקודה : Aws sync s3://flaws2-logs

Sync:

היא פקודה שמבצעת באופן רקורסיבי העתקה של קבצים חדשים/קבצים שהשתנו במקור היעד, היא מתאימה יותר לספריות גדולות בהשוואה ל CP, היא שומרת על סינכרון המקור והיעד כאשר קבצים מתווספים באופן הדרגתי למקור

S3://flaws2-logs –

זהו בעצם נתיב המקור להורדת הדוחות בבאקט של חשבון securityn, אחריו רק צריך לציין את נתיב היעד להורדת הדוחות. כמו שרואים בתמונה השנייה בוצעה הורדה מוצלחת של כל הלוגים לנתיב במכונת הקאלי

משימה 2: גישה לחשבון Target

שיטת ההגדרה המומלצת (best practice) עי AWS היא להחזיק בחשבון אבטחה נפרד המכיל את יומני האירועים של AWS, לשם כך אנחנו צריכים לקשר את חשבון ה Security עם חשבון Targetn המכיל את היומנים על מנת שתהיה לנו גישה גם ליומני האירועים

```

(shlomi@s)-[~/aws]
$ cat config
[profile security]
region = us-east-1
output = json
[profile shlomi]
region = us-east-1
[profile ifsafeuser]
region = us-east-1
output = json
[profile itsafeuser]
region = us-east-1d
[profile target_security]
region=us-east-1
output=json
source_profile = security
role_arn = arn:aws:iam::653711331788:role/security

(shlomi@s)-[~/aws]
$ aws --profile target_security sts get-caller-identity

{
  "UserId": "AROAIKRY5GULQLY0GRMNS:botocore-session-1744830276",
  "Account": "653711331788",
  "Arn": "arn:aws:sts::653711331788:assumed-role/security/botocore-session-1744830276"
}

(shlomi@s)-[~/aws]
$ aws --profile target_security s3 ls
2018-11-20 21:50:08 flaws2.cloud
2018-11-20 20:45:26 level1.flaws2.cloud
2018-11-21 03:41:16 level2-g9785tw8478k4awxtbox9kk3c5ka8iiz.flaws2.cloud
2018-11-26 21:47:22 level3-oc6ou6dnkw8sszwvdrxaxc5t5udrsw3s.flaws2.cloud
2018-11-27 22:37:27 the-end-962b72bjahfm5b4wcktm8t9z4sapemjb.flaws2.cloud

```

אחרי ההתחברות הראשונית לCLI ובכלל עם חשבון "security" נוצר לנו תקיה מוסתרת
 /aws
 נרשום ב shell את הפקודה ls -a ונוכל לראות אותה
 בתוך התקיה ישנו את פרטי ההתחברות של המשתמשים ב CLI בקובץ בשם "config" וגם
 את קובץ ה credentials שמכיל את ה access\secret keys של המשתמשים
 נוסיף לקובץ config את חשבון ה Target - שה source של החשבון הוא חשבון ה security
 וה role_arn שקיבלנו לחיבור החשבון
 ונוודא התחברות עי הפקודה:

"aws --profile target_security sts get-caller-identity"

aws --profile target_security שם הפרופיל שבשמו מתבצעת הפקודה
 Sts- כמו במשימה הקודמת זהו הסרוויס המאפשר לנו לייצור גישה למערכת לזמן מוגבל
 —get-caller-identity יבוא של זהות המשתמש
 בפרט שהתקבל אנחנו רואים את החשבון target שהמוצמד לחשבון ה security
 עי assumed-role

אחרי זה ביצעתי את הפקודה:

"aws --profile target_security s3 ls"

שהפקודה הזאת בצעם הינה : ביצוע ליסטינג לבאקט עם פרופיל ה Target
 profile--ביצוע הפקודה בשם משתמש
 Target_security-זהו הפרופיל המשתמש שבשמו מתבצעת הפקודה
 —S3 זהו הבאקט המכיל את יומני האירועים
 Ls-פקודה לביצוע list file בלינוקס

בפלט שהתקבל בתמונה הנ"ל אנחנו רואים את יומני האירועים שהתקבלו

משימה 3-שימוש בjq

במשימה הזאת אנחנו רואים שימוש ב jq-הוא כלי שמשמש לניתוח וסיון שינוי ועיבוד נתונים ממסמכי JSON ובכך הוא הופך את המסמך לקריא יותר

פקודה ראשונה: `find . -type f -exec gunzip {} \;`

Find- פקודה חזקה לחיפוש קבצים ותקיות בלינוקס שנוכל לבסס את החיפוש לפי קריטריונים שונים כמו שם, גודל, סוג

. -הנקודה הינה מעידה על חיפוש בתקייה נוכחית-נוכל להחליף את הנקודה בנתיב המלא של תקיית הלוגים

f Type-מגביל את החיפוש לקבצים רגילים בלבד

Exec- מאפשר לשרשר פקודות עם החיפוש כמו הפקודה הבאה במקרה שלנו - `gunzip` שתחלץ לנו את הקבצים

Gunzip-זהו כלי דחיסת קבצים שנועד לדחוס רק קבצים בודדים-כל הרעיון הוא להקטין גודל של קבצים

{}-הסימבול הזה מחליף את שמות הקבצים לחיפוש ובכך מורה על כל הקבצים במקרה הזה

; -מסיים את שרשר הפקודה שהתחלנו עם `exec`

```
shlomi@z:~$ find -type f -exec gunzip {} \;
shlomi@z:~$ find -type f -exec cat {} \; | jq
{
  "Records": [
    {
      "eventVersion": "1.05",
      "userIdentity": {
        "type": "AssumedRole",
        "principalId": "AROA3QMBOWMIK1ZKMF64:d190d14a-2404-45d6-9113-4eda22d7f2c7",
        "arn": "arn:aws:sts:653711331788:assumed-role/level3/d190d14a-2404-45d6-9113-4eda22d7f2c7",
        "accountId": "653711331788",
        "accessKeyId": "AKIA3QMBOWMIK1ZKMF64",
        "sessionContext": {
          "attributes": {
            "mfaAuthenticated": "false",
            "creationDate": "2018-11-28T22:31:59Z"
          },
          "sessionIssuer": {
            "type": "Role",
            "principalId": "AROA3QMBOWMIK1ZKMF64",
            "arn": "arn:aws:iam:653711331788:role/level3",
            "accountId": "653711331788",
            "userName": "level3"
          }
        }
      },
      "eventTime": "2018-11-28T22:31:59Z",
      "eventSource": "aws.amazonaws.com",
      "eventName": "ListBuckets",
      "eventType": "AwsEvent",
      "sourceIPAddress": "186.102.223.250",
      "userAgent": "aws-cli/2.16.19 Python/2.7.10 Darwin/17.0 boto3/1.12.9",
      "requestParameters": null,
      "responseElements": null,
      "requestID": "6505538033d27f",
      "eventID": "65c1110b-83ae-4a08-b073-16291a894873"
    }
  ]
}
```

אחרי שחילצנו בפקודת החיפוש הקודמת את הקבצים ב `gunzip`

פקודה שנייה: `find . -type f -exec cat {} \; | jq '.'`

כמו בפקודה הראשונה אנחנו בממשיכים בחיפוש של קבצים בלבד בתקייה של `cloudtrail`

הפעם רק משלבים את `cat`

Cat - היא פקודה המשמשת להצגת התוכן של הקובץ בטרמינל-בצעם הדפסתו על המסך

\- סיום השירשור של הפקודות חיפוש עם cat כולל הצגה של כל התוכן של הקבצים שנמצאו

| -הפייפ בלינוקס מפנה את הפלט של הפקודה הקודמת לעבר הפקודה הנוכחית-במקרה שלנו זה ה Jq

Jq – הפקודה החדשה אחרי הפייפ לניתוח במסמכי JSON

'- הנקודה מסמנת במקרה הזה ל Jq לבצע ניתוח לכל המסמך ללא כולל ערך של סינון או פילטר

כמו שרואים בתמונה הנ"ל הפלט שהתקבל עם Jq אנחנו מקבלים מסמך קריא ומסודר יותר עם Jq אבל עם המון מידע

פקודה שלישית: " jq '.records[] .eventName' "

```
(shlomi@s)-[~/.../us-east-1/2018/11/28]
$ find . -type f -exec cat {} \; | jq '.Records[]|.eventName'

"ListBuckets"
"GetObject"
"GetObject"
"GetObject"
"Invoke"
"BatchGetImage"
"GetDownloadUrlForLayer"
"GetObject"
"GetObject"
"CreateLogStream"
"AssumeRole"
"CreateLogStream"
"CreateLogStream"
"ListImages"
"CreateLogStream"
```

בעצם אנחנו מסננים את המסמך של כל ה records ורוצים לדעת עם הפקודה השלישית רק את שמות האירועים שמכין ה json ,

Records[] – מסמן ל Jq לפלטר לנו בתוך תחום ה records של המסמך

| - מפריד בין סינון ה records לבין סינון ה eventName

-eventName זהו שמות האירועים מתוך כל תחום ה records בתוך מסמך ה JSON

כמו שהתקבל בפלט המידע אינו מספיק לנו-ויש לנו רק את הפעולות שקרו בחשבון אז בפקודה הרביעית אנחנו מוסיפים את זמן האירוע

פקודה רביעית: " jq -cr '.records[] | [.eventTime, .eventName] | @tsv' sort "

Jq-הוא הכלי שלנו לניתוח המסמך ה json

-Cr מדפיס לנו את כל הפלט שנבקש בשורה אחת

Records[] -תחום כל האירועים של מסמך ה JSON

| -הפרדה בין ניתוח ה records לסינון הבא

EventTime -זמני האירועים שמופעים במסמך

eventName -שמות האירועים שמופיעים במסמך

@tsv -מייצר לנו טבלה מהנתונים שביקשנו לנתח

Sort - משמשת לסדר את שורות הפלט בסדר אלפביתי עולה, אם יש שורות כפולות היא תשמור עותק של כל שורה ייחודית

```
(shlomi@ s)~[~/us-east-1/2018/11/28]
$ find . -type f -exec cat {} \; | jq -cr '.Records[]|.eventTime, .eventName|@tsv' | sort

2018-11-28T22:31:59Z    AssumeRole
2018-11-28T22:31:59Z    AssumeRole
2018-11-28T23:02:56Z    GetObject
2018-11-28T23:02:56Z    GetObject
2018-11-28T23:02:56Z    GetObject
2018-11-28T23:02:56Z    GetObject
2018-11-28T23:02:57Z    GetObject
2018-11-28T23:03:08Z    GetObject
2018-11-28T23:03:08Z    GetObject
2018-11-28T23:03:08Z    GetObject
2018-11-28T23:03:08Z    GetObject
2018-11-28T23:03:08Z    GetObject
2018-11-28T23:03:11Z    GetObject
2018-11-28T23:03:11Z    GetObject
2018-11-28T23:03:12Z    AssumeRole
2018-11-28T23:03:12Z    CreateLogStream
```

פקודה חמישית: הוספה של עוד פרמטרים לניתוח של המסמך אירועים

```
find . -type f -exec cat {} \; | jq -cr '.Records[]|.eventTime, .sourceIpAddress,
.userIdentity.arn, .userIdentity.accountId, .userIdentity.type, .eventName|@tsv' |
sort
```

פירוט של הפרמטרים שהתווספו:

sourceIpAddress -כתובת ה ip שבעצם ביצעה את הפקודה

userIdentity.arn – ARN של המשתמש בAWS באותה פקודה ספציפית

userIdentity.accountId -מזהה החשבון של המשתמש בAWS באותה פקודה ספציפית

userIdentity.type -סוג המשתמש באותו פקודה ספציפית -יכול להיות
account\service\role שביצע את הפעולה בחשבון

```
(shlomi@ ~) - [~/./-us-east-1/2018/11/28]
$ find . -type f -exec cat {} \; | jq -cr '.Records[] | [.eventTime, .sourceIPAddress, .userIdentity.arn, .userIdentity.accountId, .userIdentity.type, .eventName] | @tsv' | sort

2018-11-28T22:31:59Z    ecs-tasks.amazonaws.com    AWSService    AssumeRole
2018-11-28T22:31:59Z    ecs-tasks.amazonaws.com    AWSService    AssumeRole
2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:02:57Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:11Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:12Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
2018-11-28T23:03:12Z    lambda.amazonaws.com    AWSService    AssumeRole
2018-11-28T23:03:13Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
2018-11-28T23:03:13Z    apigateway.amazonaws.com    AWSService    Invoke
2018-11-28T23:03:14Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:17Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:18Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:03:20Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
2018-11-28T23:03:20Z    apigateway.amazonaws.com    AWSService    Invoke
2018-11-28T23:03:35Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
2018-11-28T23:03:50Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
2018-11-28T23:04:54Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    ListObjects
2018-11-28T23:05:10Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:05:12Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:05:12Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:05:53Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    ListImages
2018-11-28T23:06:17Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    BatchGetImage
2018-11-28T23:06:33Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    GetDownloadUrlForLayer
2018-11-28T23:07:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:07:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:09:28Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/d190d14a-2404-45d6-9113-4eda22d7f2c7    653711331788    AssumedRole    ListBuckets
2018-11-28T23:09:36Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
2018-11-28T23:09:36Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject

(shlomi@ ~) - [~/./-us-east-1/2018/11/28]
$
```

הפלט הסופי מראה לנו בצורה מסודרת את כל האירועים שהתרחשו בחשבון בצורת של טבלה ונוכל ליצא את הקובץ לתוכנות שונות כמו אקסל וכו -שם יהיה לנו יותר קל לעבוד על המסמך

```
n, .userIdentity.accountId, .userIdentity.type, .eventName] | @tsv' | sort > /home/shlomi/Desktop/report.txt
```

אני בחרתי ליצא את כל החיפוש למכונת הקאלי שלי עם > (stdout) שמוציא את כל הפלט לתוך קובץ

```
Text Editor
Simple Text Editor: document Help

~/Desktop/report.txt - Mousepad

1 2018-11-28T22:31:59Z    ecs-tasks.amazonaws.com    AWSService    AssumeRole
2 2018-11-28T22:31:59Z    ecs-tasks.amazonaws.com    AWSService    AssumeRole
3 2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
4 2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
5 2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
6 2018-11-28T23:02:56Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
7 2018-11-28T23:02:57Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
8 2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
9 2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
10 2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
11 2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
12 2018-11-28T23:03:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
13 2018-11-28T23:03:11Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
14 2018-11-28T23:03:12Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
15 2018-11-28T23:03:12Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
16 2018-11-28T23:03:12Z    lambda.amazonaws.com    AWSService    AssumeRole
17 2018-11-28T23:03:13Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
18 2018-11-28T23:03:13Z    apigateway.amazonaws.com    AWSService    Invoke
19 2018-11-28T23:03:14Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
20 2018-11-28T23:03:17Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
21 2018-11-28T23:03:18Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
22 2018-11-28T23:03:20Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
23 2018-11-28T23:03:20Z    apigateway.amazonaws.com    AWSService    Invoke
24 2018-11-28T23:03:35Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
25 2018-11-28T23:03:50Z    34.234.236.212    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    CreateLogStream
26 2018-11-28T23:04:54Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    ListObjects
27 2018-11-28T23:05:10Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
28 2018-11-28T23:05:12Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
29 2018-11-28T23:05:12Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
30 2018-11-28T23:05:53Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    ListImages
31 2018-11-28T23:06:17Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    BatchGetImage
32 2018-11-28T23:06:33Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/level1    653711331788    AssumedRole    GetDownloadUrlForLayer
33 2018-11-28T23:07:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
34 2018-11-28T23:07:08Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
35 2018-11-28T23:09:28Z    104.102.221.250    arn:aws:sts::653711331788:assumed-role/level1/d190d14a-2404-45d6-9113-4eda22d7f2c7    653711331788    AssumedRole    ListBuckets
36 2018-11-28T23:09:36Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
37 2018-11-28T23:09:36Z    104.102.221.250    ANONYMOUS_PRINCIPAL    AWSAccount    GetObject
38
```

פה יש לנו כבר את קובץ report.txt שאפשר לעבוד עליו בנוחות יותר במכונת הקאלי

משימה 4: זיהוי גניבת האישורים

פקודה ראשונה : `jq '.Records[]|select(.eventName=="ListBuckets")'`
נסה לסנן בפקודה הזאת את הניתוח של המסמך רק לפי האירועים שהם ליסטינג לבאקט
עי:

`select(.eventName=="listbuckets")` : שהסיון יתבצע לפי בחירה(`select`) שהיא רק אם שם
האירוע הוא `listbuckets` וכך קיבלנו את הפלט הבא

```
(shlomi@ s) - [~/.../us-east-1/2018/11/28]
$ find . -type f -exec cat {} \; | jq '.Records[]|select(.eventName=="ListBuckets")'

{
  "eventVersion": "1.05",
  "userIdentity": {
    "type": "AssumedRole",
    "principalId": "AROAJQMBDNUMIKLZKMF64:d190d14a-2404-45d6-9113-4eda22d7f2c7",
    "arn": "arn:aws:sts::653711331788:assumed-role/level3/d190d14a-2404-45d6-9113-4eda22d7f2c7",
    "accountId": "653711331788",
    "accessKeyId": "ASIAZQNB3KHGNXWXSJS",
    "sessionContext": {
      "attributes": {
        "mfaAuthenticated": "false",
        "creationDate": "2018-11-28T22:31:59Z"
      },
      "sessionIssuer": {
        "type": "Role",
        "principalId": "AROAJQMBDNUMIKLZKMF64",
        "arn": "arn:aws:iam::653711331788:role/level3",
        "accountId": "653711331788",
        "userName": "level3"
      }
    }
  },
  "eventTime": "2018-11-28T23:09:28Z",
  "eventSource": "s3.amazonaws.com",
  "eventName": "ListBuckets",
  "awsRegion": "us-east-1",
  "sourceIPAddress": "104.102.221.250",
  "userAgent": "[aws-cli/1.16.19 Python/2.7.10 Darwin/17.7.0 botocore/1.12.9]",
  "requestParameters": null,
  "responseElements": null,
  "requestID": "469859389338B27F",
  "eventID": "65e111a0-83ae-4ba8-9673-16291a804873",
  "eventType": "AwsApiCall",
  "recipientAccountId": "653711331788"
}
```

בפלט שהתקבל אנחנו מזהים שה `role` של `level3` איפשר ל `listBuckets` הזה לקרות

פקודה שניה: `aws --profile target_security iam get-role --role-name level3`

בצעם בפקודה הזאת אנחנו מייבאים את האישור של `level3` תחת המשתמש
`target_security`

`iam` - זהו שירות גלובלי של ניהול הזהויות והגישה של המשתמשים בAWS

Identity and access management

Get-role - ייבוא האישור

`--role name level3` שם ה `role` שאנחנו רוצים לייבא במקרה הזה - `level3`


```
(shlomi@s)-[~/.../us-east-1/2018/11/28]
$ aws --profile target_security iam get-role --role-name level3

{
  "Role": {
    "Path": "/",
    "RoleName": "level3",
    "RoleId": "AROAJQMBDNUMIKLZKMF64",
    "Arn": "arn:aws:iam::653711331788:role/level3",
    "CreateDate": "2018-11-23T17:55:27+00:00",
    "AssumeRolePolicyDocument": {
      "Version": "2012-10-17",
      "Statement": [
        {
          "Sid": "",
          "Effect": "Allow",
          "Principal": {
            "Service": "ecs-tasks.amazonaws.com"
          },
          "Action": "sts:AssumeRole"
        }
      ]
    },
    "Description": "Allows ECS tasks to call AWS services on your behalf.",
    "MaxSessionDuration": 3600,
    "RoleLastUsed": {
      "LastUsedDate": "2025-04-14T01:11:39+00:00",
      "Region": "us-east-1"
    }
  }
}
```

בפלט שהתקבל אנו רואים את האישור של level3 שמאפשר ל ECS-tasks לבצע אינטגרציה עם סרוויסים השונים בAWS כמו כן במקרה שלנו-שבוצעה awsapicall לבאקט שלנו ובוצע לינסטינג לבאקט מקו לא מוכר (104.102.221.250)

Ecs - הוא שירות ניהול קונטיינרים שמספקת חברת אמזון, השירות מאפשר למפתחים להריץ, להפסיק ולנהל קונטיינרים בקלות וביעילות

משוב על קורס practitioner+cloud security

יש לציין שמאוד נהנתי בשני הקורסים, העבודה בAWS הייתי מאתגרת וכמו שראיתי בהרבה מקרים בחיפוש שלי אחר כיוונים באינטרנט הקורסים מעודכנים, היה חסר לי קצת שאלות/בחינות קטנות במיוחד בנושא הסרוויסים הרבים, הכי נהנתי מהאינטרקציה של AWS עם CLI, ניסיתי המון דברים עם CLI שלא היו בשיעור...הקמות של אינסטנס, חיבור הבאקט ל winscp וכו

תודה רבה על הידע היקר שהעברתם לנו, שלומי גרין